

CISSP Printable Practice Exam 18 - Domain 2 - Asset Security

Practice Exam 03 - Domain 2

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP3-025)

Scenario: A consumer-lending company builds a forecasting model from several internal datasets. The model does not contain complete source records, but its parameters and outputs can reveal confidential pricing strategy and patterns about high-value customer segments.

How should the model be classified?

- A. As public, because the model does not contain complete source records
- B. According to the sensitivity and business impact of what the model and its outputs can reveal
- C. At the same level as the least sensitive source dataset used for training
- D. Only after an external party demonstrates that confidential information can be inferred

Question 2 (CISSP3-026)

Scenario: Executives at a food-distribution company plan to discuss a confidential acquisition during a conference. The reserved room has thin partitions, visitors use the adjacent space, and notes from prior meetings remain on a whiteboard.

Which action BEST satisfies the handling requirement?

- A. Proceed because classification labels apply only to recorded information.
- B. Ask attendees to speak quietly and erase the whiteboard after the discussion.
- C. Hold the meeting as planned but prohibit attendees from taking written notes.
- D. Move the discussion to an approved private location and clear residual information before and after use.

Question 3 (CISSP3-027)

Scenario: During an inventory review, a cloud operations team finds a repository containing years of partner performance data. The original business unit was dissolved, no successor owner is documented, and the operations team cannot determine whether a new analytics request is an authorized use.

What should the cloud custodian do FIRST?

- A. Escalate the ownership gap so an accountable business owner can be assigned before use and classification decisions are made.
- B. Approve the analytics request because custodians control the repository.
- C. Delete the repository immediately because every asset must have a current owner.
- D. Allow read-only access while waiting for a future organizational restructuring.

Question 4 (CISSP3-028)

Scenario: A mining company uses four information classifications, but departments display different abbreviations and colors for the same level. Employees transferring between sites frequently misinterpret which sharing and storage rules apply.

Which improvement would MOST directly reduce the handling errors?

- A. Allow each site to keep local markings and publish a yearly comparison chart.
- B. Replace classification markings with the name of the department that created the information.
- C. Standardize labels and associate each label with centrally defined handling

requirements.

D. Remove visible labels and rely on users to determine sensitivity from context.

Question 5 (CISSP3-029)

Scenario: A medical-device manufacturer is reviewing information assets after selling one product line and entering a new jurisdiction. Some records have lost operational value, while others are now subject to additional disclosure and handling obligations.

Which TWO actions are most appropriate? Select 2 of the 5 options below.

- A. Keep every existing classification unchanged to preserve consistency over time.
- B. Have accountable owners reassess affected assets against current sensitivity, criticality, and obligations.
- C. Let custodians lower classifications whenever storage costs increase.
- D. Update handling requirements and labels when the approved reassessment changes an asset's classification.
- E. Apply the highest classification to every record associated with both product lines.

Question 6 (CISSP3-030)

Scenario: A software company allows development teams to create temporary cloud environments for testing. Many environments lack an owner tag, use inconsistent configurations, and continue running months after the associated projects end.

Which control would BEST address the lifecycle weakness?

- A. Provision environments through approved templates that require ownership, inventory registration, and expiration metadata.
- B. Allow unrestricted creation but ask teams to review their resources once a year.
- C. Increase the cloud budget so abandoned environments do not affect active projects.
- D. Exclude temporary resources from asset management because they are not physical devices.

Question 7 (CISSP3-031)

Scenario: A news organization must return a malfunctioning workstation under warranty. The device contains nonremovable storage that held embargoed investigative material, and the vendor may replace rather than return the original unit.

What is the MOST appropriate action before releasing the workstation?

- A. Send the workstation immediately because the warranty agreement establishes vendor ownership during repair.
- B. Delete visible files and rely on the vendor's standard intake process.
- C. Apply the approved media-handling procedure, including verified sanitization when feasible or an authorized exception with controlled custody.
- D. Ask the reporter who used the workstation to decide whether the remaining information is sensitive.

Question 8 (CISSP3-032)

Scenario: A biotechnology startup frequently prepares new employees by copying the access and equipment assignments of whoever previously held a similar title. Managers do not confirm current duties, and accounts sometimes become active days before the employee's start date.

Which change would provide the STRONGEST provisioning control?

- A. Continue copying prior assignments but require the new employee to report

unnecessary access.

- B. Activate every account early so managers can test the employee's access before arrival.
- C. Use job titles as the sole basis for all access and equipment decisions.
- D. Require manager-approved role needs, effective dates, least-privilege access, and documented receipt of assigned assets.

Question 9 (CISSP3-033)

Scenario: An international shipping company finds that a contract requires certain transaction records to be kept for four years, while an applicable regulation requires the same records for seven years. The business unit would prefer two years to reduce storage cost.

Which retention period should the records owner adopt?

- A. Two years, because the business unit owns the operational budget
- B. Seven years, after confirming applicability and documenting the controlling requirement
- C. Four years, because a signed contract is more specific than a regulation
- D. Indefinitely, because conflicting periods make scheduled disposition unsafe

Question 10 (CISSP3-034)

Scenario: A public utility is migrating records to a new document platform. The migration team has copied the files but omitted creation dates, owner assignments, legal-hold indicators, and scheduled disposition dates from its test conversion.

What should happen before the legacy platform is retired?

- A. Validate and migrate the governance metadata needed to preserve retention, ownership, and hold requirements.
- B. Reset every migrated record to a new full retention period beginning on the migration date.
- C. Retain the legacy platform permanently as the only source of recordkeeping metadata.
- D. Let users recreate metadata only when they next open a migrated record.

Question 11 (CISSP3-035)

Scenario: A property-management company regularly clones production databases for troubleshooting. The temporary environments are deleted, but their storage snapshots remain for years, retain production classifications, and are accessible to a larger administrator group than the source systems.

What is the BEST corrective action?

- A. Keep the snapshots because deleting the temporary environments removes the primary exposure.
- B. Rename the snapshots so administrators understand that they are no longer active.
- C. Inventory the snapshots as data copies, restrict access, and apply approved retention and secure disposition requirements.
- D. Transfer all snapshots to lower-cost storage without changing permissions or retention.

Question 12 (CISSP3-036)

Scenario: A global agricultural company is selecting a data protection standard for research data used in laboratories, shared with universities, stored in cloud services, and archived for patent support. One team recommends adopting whichever standard is easiest for its

current tools to implement.

Which selection approach is MOST appropriate?

- A. Select the least costly standard and address uncovered risks after incidents occur.
- B. Derive requirements from classification, lifecycle uses, applicable obligations, and risk, then scope and tailor the selected controls.
- C. Use the laboratory team's preferred controls for every environment without modification.
- D. Allow each external university to define the company's protection standard.

Question 13 (CISSP3-037)

Scenario: A recording studio is retiring write-once optical discs containing unreleased material and reusable magnetic tapes containing restricted project backups. Both media sets will leave organizational custody; the tapes support an approved purge technique and will be resold.

Which TWO disposition decisions are most appropriate? Select 2 of the 5 options below.

- A. Physically destroy the optical discs with an approved process that renders their data unrecoverable.
- B. Clear the optical discs by deleting their directory entries before recycling.
- C. Relabel the magnetic tapes as blank without performing sanitization.
- D. Purge and verify the magnetic tapes using the approved technique before resale.
- E. Retain both media sets indefinitely because external disposition cannot be made risk-free.

Question 14 (CISSP3-038)

Scenario: A benefits administrator wants to strengthen protection for enrollment data. Interviews reveal that information moves from a web form to a processing service, reporting warehouse, support queue, partner feed, and archive, but no complete flow or copy inventory exists.

What should the security architect do FIRST?

- A. Purchase a data protection product that covers the web form and expand it later.
- B. Protect only the archive because it contains the longest-lived copy.
- C. Ask each system administrator to select controls independently for the local copy.
- D. Map the end-to-end data lifecycle, including copies, transfers, ownership, access, retention, and destruction points.

Question 15 (CISSP3-039)

Scenario: A university's application team copies complete student records into a testing environment to reproduce software defects. Testers need realistic formats and relationships, but they do not need actual student identities or contact details.

Which control BEST supports the testing requirement while reducing exposure?

- A. Continue using complete records because the testers are employees.
- B. Move the testing environment to a separate network while leaving the data unchanged.
- C. Use appropriately de-identified, tokenized, or synthetic test data that preserves required formats and relationships.
- D. Archive the production records immediately after each test cycle.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP3-025) - Correct: B

A derived analytical asset should be classified according to the information it exposes and the impact of unauthorized disclosure, alteration, or loss. The absence of complete source records does not make the model public. Using the least sensitive input understates risk, and waiting for demonstrated external inference is reactive rather than risk-based.

Question 2 (CISSP3-026) - Correct: D

Handling obligations follow confidential information regardless of whether it is digital, printed, written on a board, or spoken. An approved private location and removal of residual information address both eavesdropping and visual exposure. Speaking quietly or restricting notes does not adequately control the environment.

Question 3 (CISSP3-027) - Correct: A

The custodian should preserve the asset and escalate the missing accountability so an authorized business owner can determine classification, permitted use, and disposition. Operating the repository does not grant business decision authority. Immediate deletion may violate retention needs, while provisional access could enable an unauthorized secondary use.

Question 4 (CISSP3-028) - Correct: C

Consistent labels tied to defined handling rules give users a common, actionable indication of how assets must be protected. Local variations preserve ambiguity, department names do not express sensitivity, and removing labels forces subjective decisions that increase inconsistent handling.

Question 5 (CISSP3-029) - Correct: B, D

Material changes in business use and legal context warrant an owner-led reassessment, followed by updated labels and handling rules when the classification changes. Freezing all classifications ignores current risk, custodians should not downgrade assets for cost reasons, and classifying everything at the highest level creates unnecessary restrictions without a risk-based basis.

Question 6 (CISSP3-030) - Correct: A

Temporary virtual resources remain organizational assets and need secure, accountable provisioning. Approved templates combined with required ownership, inventory, and expiration data enable consistent deployment and timely retirement. Annual review is too slow, additional budget does not reduce exposure, and excluding virtual assets creates unmanaged infrastructure.

Question 7 (CISSP3-031) - Correct: C

An asset leaving organizational control requires treatment based on its data sensitivity and the ability to sanitize the media. Verified sanitization is preferred; if it is infeasible, an authorized exception and controlled custody are needed. Warranty status does not transfer accountability, ordinary deletion may leave remanent data, and the individual user should not replace the approved process.

Question 8 (CISSP3-032) - Correct: D

Secure onboarding begins with current, approved job needs and coordinates activation timing, least privilege, and accountable asset assignment. Copying another person's profile can reproduce obsolete or excessive permissions. Early activation creates avoidable exposure, and job titles alone may not reflect actual responsibilities.

Question 9 (CISSP3-033) - Correct: B

After confirming that both requirements apply, the organization must satisfy the longer mandatory period and document the basis for the schedule. Cost preference cannot shorten a binding obligation, the contract does not negate the regulation, and indefinite retention adds risk beyond the stated requirements without justification.

Question 10 (CISSP3-034) - Correct: A

A records migration must preserve the metadata that makes retention, ownership, holds, and defensible disposition enforceable. Restarting every retention period creates unnecessary over-retention, preserving the old platform indefinitely avoids rather than solves the migration problem, and user reconstruction would be incomplete and inconsistent.

Question 11 (CISSP3-035) - Correct: C

Snapshots remain data assets even after the associated environment is removed. They must be inventoried, protected according to classification, retained only as required, and securely disposed of when no longer needed. Renaming or moving them does not reduce unauthorized access or over-retention, and environment deletion does not eliminate the copied data.

Question 12 (CISSP3-036) - Correct: B

The standard should be driven by the information's classification, lifecycle, legal and contractual obligations, operating environments, and risk. Scoping and tailoring then adapt controls while preserving required outcomes. Tool convenience, one environment's preferences, or external recipients alone should not define enterprise protection requirements.

Question 13 (CISSP3-037) - Correct: A, D

Write-once optical media intended for disposal should be physically destroyed using an approved process. Reusable magnetic tapes leaving custody may be purged with a supported, approved technique and verified before resale. Deleting directory entries or relabeling media does not address remanence, while indefinite retention creates continuing exposure without a business need.

Question 14 (CISSP3-038) - Correct: D

A complete lifecycle and data-flow map establishes where the information exists, how it moves, who is accountable, and where controls and disposition must apply. Product selection before understanding scope may leave major gaps. Focusing on one copy or delegating disconnected local decisions cannot provide consistent end-to-end protection.

Question 15 (CISSP3-039) - Correct: C

Protected or synthetic test data can preserve the structure needed for testing without exposing unnecessary real identities. Employment status does not create a need for complete records. Network separation is useful but does not minimize the copied data, and archiving after use does not prevent exposure during the test cycle.